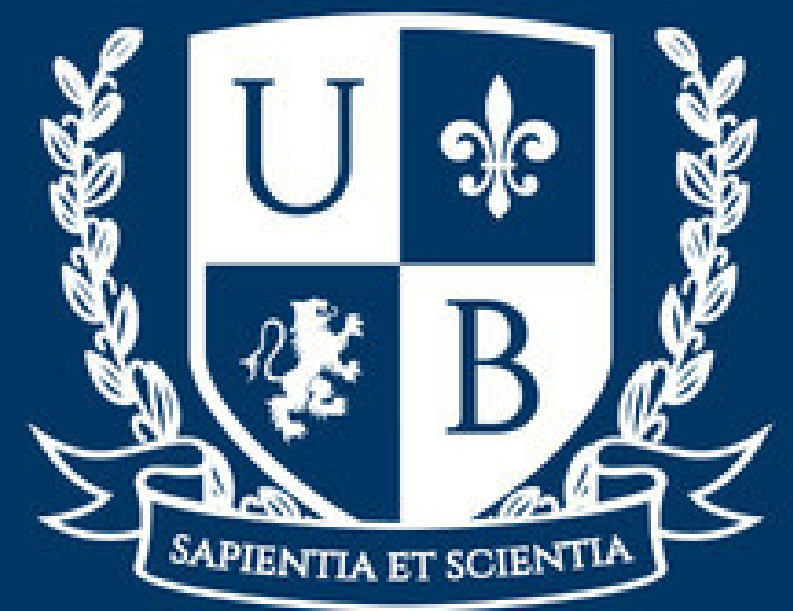


Segurança da Informação

Aula 02: Fundamentos de Segurança da Informação
Professor: Francisco Erberto



O que é segurança da Informação?

É a proteção da informação contra vários tipos de ameaças para garantir a continuidade do negócio, minimizar riscos, maximizar o retorno sobre os investimentos e as oportunidade de negócios” [ISO 27002].

- A expansão da Internet gerou novos aspectos de negócios, ampliando a atuação das empresas e atingindo novos segmentos e mercados.
- A evolução dos ambientes informatizados levou as informações empresariais para o formato digital.
- Se isso abriu as portas da empresa para o mundo, as informações devem ser protegidas.

O que devemos proteger?

- Registro de negócios;
- Bases de dados dos clientes;
- Informações Pessoais;
- Registros financeiros e transações;
- Base de dados de informações.

Um ataque bem sucedido pode resultar em:

- Prejuízo à imagem da empresa;
- Diminuição na produtividade;
- Perda de mercado;
- Vazamento de informações confidenciais;
- Prejuízo financeiro.

Fundamentos

A segurança da informação é baseada em **3 pilares (CID)**:

- Confidencialidade
- Integridade
- Disponibilidade

Envolve: Tecnologias, Processos, Pessoas

As pessoas são, normalmente, o elo mais fraco, portanto o mais explorado por atacantes.

Fundamentos

Pilar	Definição	Objetivo	Exemplos
Confidencialidade	Garantir que apenas pessoas autorizadas tenham acesso à informação	Proteger dados contra acesso não autorizado	Criptografia de dados, controle de acesso por senha, permissões de usuário
Integridade	Assegurar que a informação permaneça correta e não seja alterada indevidamente	Manter confiabilidade e precisão dos dados	Hash de arquivos, assinaturas digitais, controle de versão
Disponibilidade	Garantir que sistemas e dados estejam acessíveis quando necessários	Evitar interrupções e indisponibilidade	Backups, redundância de servidores, proteção contra DDoS
Autenticidade	Confirmar a identidade de usuários e a origem das informações	Garantir que quem acessa ou envia é quem diz ser	Certificados digitais, autenticação multifator, biometria
Não repúdio	Impedir que uma ação realizada seja negada posteriormente	Garantir rastreabilidade e responsabilidade	Logs auditáveis, assinatura digital em contratos

Engenharia Social

- Práticas utilizadas para obter acesso a informações importantes ou sigilosas em organizações ou sistemas por meio da enganação ou exploração da confiança das pessoas.
- Ataca o elemento mais vulnerável de qualquer sistema de segurança da informação: o ser humano.
- Ao realizar o ataque, o “Engenheiro social” pode fazer uso de qualquer meio de comunicação.

Vulnerabilidades

Falha ou fraqueza de procedimento, design, implementação, ou controles internos de um sistema que possa ser acidentalmente ou propositalmente explorada, resultando em uma brecha de segurança ou violação da política de segurança do sistema;

Ameaça

Possibilidade de um agente (ou fonte de ameaça) explorar acidentalmente ou propositalmente uma vulnerabilidade específica;

Risco

Probabilidade de uma fonte de ameaça explorar uma vulnerabilidade, resultando em um impacto para a organização.

Vulnerabilidades Tecnologicas

- Protocolos
- Sistema Operacional
- Equipamentos de Rede

Vulnerabilidades de Configuração

- Manter configurações default inseguras
- Contas de sistemas com senhas previsíveis
- Configuração equivocada de equipamentos ou serviços.

Ameaças Acidentais

- Falhas de equipamentos
- Erros humanos
- Falhas de software
- Problemas causados por forças da natureza

Ameaças Propositais

- Espionagem;
- Crimes;
- Empregados insatisfeitos;
- Empregados desonestos;
- Vandalismo;
- Terrorismo.

Ataques na Internet

- Exploração de vulnerabilidades
- Varredura em redes (Scan)
- Falsificação de e-mail (E-mail spoofing)
- Interceptação de tráfego (Sniffing)
- Força bruta (Brute force)
- Desfiguração de página (Defacement)
- Negação de serviço (DoS e DDoS)

Golpes na Internet

- **Furto de identidade** (Identity theft): É quando alguém obtém e usa dados pessoais de outra pessoa sem autorização .
- **Fraude de antecipação de recursos** (Advance fee fraud): Ocorre quando o golpista promete um benefício futuro (empréstimo, prêmio, herança, investimento) e exige um pagamento antecipado para liberar o valor.
- **Phishing**: É uma tentativa de enganar a vítima por meio de mensagens falsas (e-mail, SMS, redes sociais).
- **Pharming**: É um golpe mais técnico: o criminoso redireciona a vítima para um site falso mesmo que ela digite o endereço correto no navegador, geralmente por manipulação de DNS ou malware, para capturar dados.

Códigos Maliciosos

- **Vírus:** Malware que se anexa a arquivos ou programas e se replica quando eles são executados, infectando o sistema.
- **Worm:** Malware que se espalha automaticamente pela rede sem precisar de ação do usuário.
- **Bot e botnet:** dispositivo infectado controlado remotamente por um atacante.
- **Spyware:** Programa que espiona a atividade do usuário e coleta dados sem consentimento.

Códigos Maliciosos

- **Backdoor:** Mecanismo que permite acesso remoto oculto a um sistema, contornando autenticação.
- **Cavalo de troia (Trojan):** Malware disfarçado de software legítimo que, ao ser executado, realiza ações maliciosas.
- **Rootkit:** Conjunto de ferramentas usadas para esconder malware e manter acesso privilegiado sem ser detectado.

Perfil do Invasor

- Hacker:
 - Estudante de computação
 - Motivos ideológicos
- Cracker:
 - Profissional motivado financeiramente
 - Objetiva fraude e furto
 - Pode ter o suporte do crime organizado em um futuro próximo

Mecanismos de Segurança

Para minimizar os riscos deve-se garantir alguns requisitos básicos de segurança, como:

- Identificação;
- Autenticação;
- Autorização;
- Integridade;
- Confidencialidade ou sigilo;
- Não repúdio;
- Disponibilidade.

Mecanismos de Segurança

- Política de segurança;
- Notificação de incidentes e abusos;
- Contas e senhas;
- Criptografia;
- Cópias de segurança (Backups);
- Registro de eventos (Logs);
- Ferramentas antimalware;
- Firewall.

Estudo de Caso: Invasão da PSN

- Em 19 de abril de 2011 membros da equipe de TI da Sony encontraram vestígios de Atividades não autorizadas em sua rede.
- No dia seguinte foram descobertos evidências de invasão ao sistema e roubo de informações, eles então resolveram tirar o serviço do ar e contrataram empresas especializadas em análise forense para investigar o caso.
- No dia 26 de abril de 2011 a Sony informou que os dados de aproximadamente 77 milhões de usuários haviam sido roubados. O FBI foi acionado para investigar o caso.
- A rede só voltou ao ar no dia 15 de maio, causando um prejuízo estimado de 24 bilhões de dólares.

Exercício

Objetivo da Atividade: Aplicar os conceitos estudados sobre Fundamentos de Segurança da Informação na análise de um pequeno negócio.

Ao final da atividade, o grupo deverá ser capaz de:

- Identificar ativos de informação
- Avaliar impactos relacionados à Confidencialidade, Integridade e Disponibilidade
- Compreender a importância estratégica da segurança da informação

Organização

- Atividade em grupos de 3 a 5 alunos

Etapa 1 – Escolha do Negócio

Escolha um pequeno negócio real ou hipotético:

- ☐ Clínica médica
- ☐ Escola
- ☐ Loja online
- ☐ Restaurante
- ☐ Escritório de contabilidade
- ☐ Pequena indústria
- ☐ Outro: _____

Etapa 2 – Identificação dos Ativos

Liste pelo menos 5 ativos de informação essenciais para o funcionamento do negócio.

Ativos de informação são dados, sistemas ou recursos que possuem valor para a organização.

Etapa 3 – Aplicação da Tríade CIA

Ativo	O que acontece se perder Confidencialidade?	O que acontece se perder Integridade?	O que acontece se perder Disponibilidade?	Impacto (Alto, Médio ou Baixo)
1				
2				

Orientações:

- Confidencialidade: acesso indevido, vazamento, exposição
- Integridade: alteração incorreta, fraude, manipulação
- Disponibilidade: sistema fora do ar, perda de acesso, indisponibilidade
- Classifique o impacto considerando consequências financeiras, legais, operacionais e reputacionais.

Etapa 4 – Análise Final

Responda:

- Qual ativo apresentou maior impacto para o negócio?
- Qual dos três pilares (C, I ou D) é mais crítico para esse ativo?
- Se você tivesse orçamento limitado, em qual controle de segurança investiria primeiro? Justifique.